

SECURITY PORTFOLIO

서비스의 동작을 이해하고,
보안 위험을 근거로 설명합니다.

윤승찬 | 정보보호학과 · 정보보안기사

클라우드 · 웹 서비스 · 취약점 점검 · 정보보호 관리체계

개발 경험과 보안 점검 경험을 갖춘 신입

웹 서비스 개발, 클라우드 프로젝트, 취약점 실습과 보안진단을 통해 보안의 여러 관점을 익혔습니다.

윤승찬

수원대학교 정보보호학과

2020.03 – 2026.02

EDUCATION & TRAINING

생성형 AI 활용 클라우드 & 보안 전문가 과정

SK 쉐더스 · SeSAC | 2024.10 – 2025.02

CERTIFICATIONS

정보보안기사 · 2026.08

정보기기운용기능사 · 2019.08

정보처리기능사 · 2019.03

컴퓨터활용능력 2 급 · 2018.08

AWS · Linux · Python · FastAPI · React · Burp Suite · ISMS-P

프로젝트로 확인할 수 있는 경험

교육과정 프로젝트 | 개인 수행 내용과 결과물을 중심으로 정리했습니다.

AWS 서버리스 공유 앨범

2024.11

보안 점검 의견 제시 · 프로젝트 발표

응답값 노출 점검 · 클라우드 구성 · 차단 /TLS 캡처

04—07

SeSAC Community

2024.11

관리자 프론트 · 백엔드 개발 · 취약점 점검 · 자문

관리자 API 문서 · CMS 소스 · 인증 구현 및 회고

08—10

ISMS-P·수탁사 보안진단

2025.01—02

준거법 조사 · 담당 체크리스트 작성 · 수탁사 조사

점검표 · 증거 기반 판단 사례 · 팀 진단 결과

11—15

추가 실습 / Burp Suite 기반 웹 요청 · 응답 및 취약점 분석

16

AWS 서버리스 공유 앨범

2024.11 | 클라우드 기반 이미지 업로드 · 조회 · 다운로드 서비스 | 교육 팀 프로젝트

담당 역할

정보보호 전공을 바탕으로
보안 점검 의견 제시

위험과 검증 내용을 정리해
프로젝트 발표 담당

팀 기술 환경

S3 · Lambda · API Gateway

MariaDB · WAF · Cognito

대표 사례 | GET 응답의 불필요한 해시값 노출

문제

이미지 조회 응답에 비밀번호 해시값이 포함되어,
서비스 이용에 불필요한 인증 관련 정보가 외부로 전달됐습니다.

팀 조치

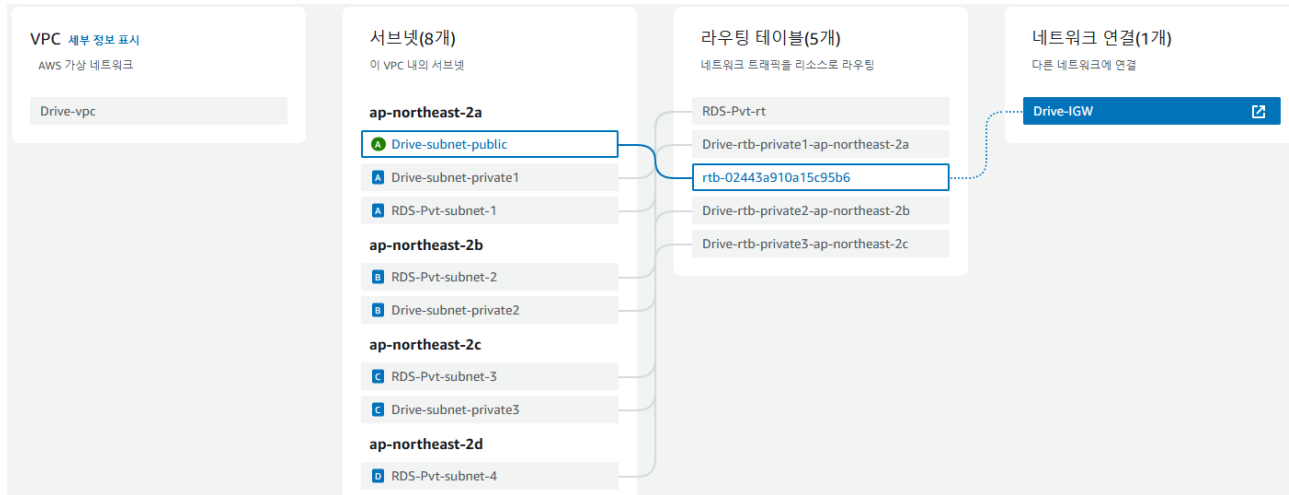
Lambda 응답에서 비밀번호 해시 필드를 제외하도록 수정했습니다.
저는 노출 위험과 보안 점검 내용을 팀에 설명했습니다.

배운 점

저장 시 해시 처리 여부와 별개로 API 응답 범위를 확인해야 합니다.
이후에는 기능별 응답 필드와 민감정보 포함 여부를 함께 살피겠습니다.

AWS 공유 앨범 : 클라우드 구성과 서비스 연결

AWS 서버리스 공유 앨범 | 팀이 구축한 서비스의 네트워크 및 API 연결 구조



함수 개요 정보

다이어그램

템플릿

drive-lambda

Layers

(0)

API 게이트웨이

(2)

+ 트리거 추가

VPC · 서브넷 · 라우팅 구성

서비스가 배치된 네트워크와 외부 연결 경로를 이해하기 위한 구성 자료

API Gateway · Lambda 연결

API 요청을 처리하는 함수와 연결 관계를 보여주는 콘솔 화면

AWS 공유 앨범 : 보안 점검 화면

AWS 서버리스 공유 앨범 | 팀 점검 자료의 차단 사례와 전송 암호화 확인 결과

01 공격 요청 차단 사례

원본 발표자료의

SQL Injection · XSS 점검

403 ERROR

The request could not be satisfied.

Request blocked. We can't connect to the server for this app or website at this time. There might be too much traffic or a configuration error. Try again later, or contact the app or website owner. If you provide content to customers through CloudFront, you can find steps to troubleshoot and help prevent this error by reviewing the CloudFront documentation.

Generated by cloudfront (CloudFront)
Request ID: AC1-64L511PZgwwiwcsagt1K0amZ#tnd0th0pvXweIEKNcnDeCZaSw==

02 TLS 전송 확인

Wireshark 캡처에서

TLS 1.3 통신 확인

900 55.864884	192.168.0.137	15.164.142.15	TLSv1.3	483 Application Data
902 55.870925	15.164.142.15	192.168.0.137	TLSv1.3	233 Application Data
903 55.870925	15.164.142.15	192.168.0.137	TLSv1.3	125 Application Data
905 55.871017	192.168.0.137	15.164.142.15	TLSv1.3	85 Application Data
906 55.875661	15.164.142.15	192.168.0.137	TLSv1.3	381 Application Data
907 55.876197	192.168.0.137	15.164.142.15	TLSv1.3	239 Application Data
909 55.889491	192.168.0.137	15.164.142.15	TLSv1.3	105 Application Data
913 56.324610	15.164.142.15	192.168.0.137	TLSv1.3	660 Application Data
914 56.324610	15.164.142.15	192.168.0.137	TLSv1.3	85 Application Data
919 56.339725	192.168.0.137	3.5.141.103	TLSv1.3	1842 Client Hello (SNI=drive-sesac-s3.s3.ap-northeast-2.amazonaws.com)
922 56.345860	3.5.141.103	192.168.0.137	TLSv1.3	181 Server Hello
923 56.345860	3.5.141.103	192.168.0.137	TLSv1.3	60 Change Cipher Spec
924 56.345860	3.5.141.103	192.168.0.137	TLSv1.3	101 Application Data
925 56.345860	3.5.141.103	192.168.0.137	TCP	1494 443 → 51821 [ACK] Seq=181 Ack=1789 Win=57344 Len=1440 [TCP PDU reassembled in 928]
928 56.345860	3.5.141.103	192.168.0.137	TLSv1.3	1344 Application Data

Frame 626: 78 bytes on wire (624 bits), 78 bytes captured (624 bits) on interface \Device\NPF_{D70EEAE1-4F...}	0000	e8 bf b8 9a e2 dc b0 4e 26 b4 91 01 08 00 45 00	N&...E
Internet II, Src: TplinkTechno_b4:91:01 (08:0e:26:b4:91:01), Dst: Intel_9a:e2:dc (e8:bf:b8:9a:e2:dc)	0010	00 40 e3 f8 48 00 37 06 bb fd 68 46 7a 4a c0 a8	@ @ 7 ...hFz...
TCP, Src Port: 443, Dst Port: 51821, Seq: 181, Len: 1440	0020	00 89 01 bb ca 13 a0 30 4d f6 26 b4 5f ce 50 18	0M&...P
Transmission Control Protocol, Src Port: 443, Dst Port: 51821, Seq: 1, Ack: 1, Len: 24	0030	01 f5 32 de 00 00 17 03 03 00 13 21 ae d5 b4 15	...2.....I....
Transport Layer Security	0040	e1 2b b4 ed 2c 6c f4 65 09 36 61 cf e4 a6	+...l e 6a...

점검 관점 : 웹 요청 차단과 전송 구간 보호를 나누어 보고, 확인한 결과를 근거 화면과 함께 설명

AWS 공유 앨범에서 배운 점 : 데이터 흐름과 보안

AWS 서버리스 공유 앨범 | 정보보호 전공을 바탕으로 보안 점검 의견을 공유하고 결과를 발표했습니다.

응답값도 점검 대상

비밀번호를 해시로 저장하더라도 그 값이 GET 응답에 포함되면 불필요하게 외부로 전달됩니다.
저장 방식뿐 아니라 각 API가 누구에게 어떤 필드를 반환하는지 확인해야 한다는 점을 배웠습니다.

통제별 역할 이해

WAF 차단과 TLS 전송 암호화 사례를 발표하며, 공격 요청을 거르는 것과 전송 데이터를 보호하는 것의 목적을 구분했습니다. 한 가지 보안 기능만으로 서비스 전체의 안전성을 판단할 수 없었습니다.

설명하며 구조 이해

S3·API Gateway·Lambda·DB의 연결을 설명하려면 요청이 어디로 가고 어떤 데이터가 돌아오는지 이해해야 했습니다. 다음에는 기능별 데이터 흐름과 응답 필드를 먼저 정리해 점검에 활용하겠습니다.

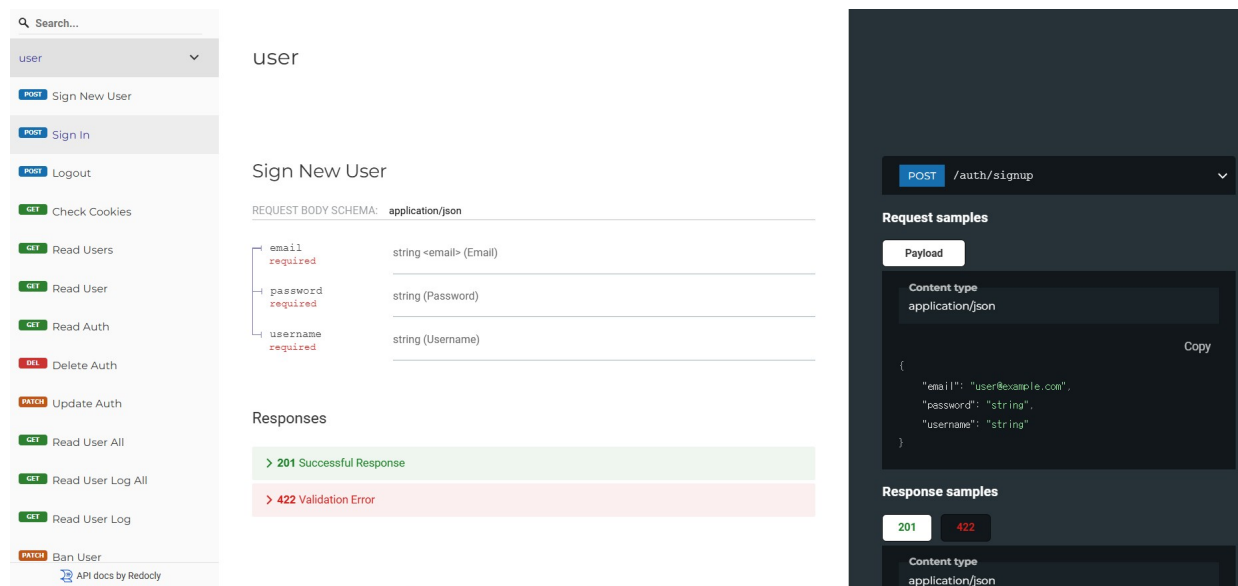
다음 적용 : API 별 요청 · 응답 필드 정리 → 민감정보 포함 여부 확인 → 조치 후 응답 재확인

SeSAC Community: 관리자 화면부터 API 까지

2024.11 | 5 인 팀 | 관리자 페이지 프론트 · 백엔드 개발 및 보안취약점 점검 · 자문

직접 구현한 기능

React 기반 관리자 화면과 API 연동
 관리자 회원가입 · 로그인 · 로그아웃
 사용자 조회 및 Ban · 해제
 게시글 삭제, 신고 · 로그 조회
 공지사항 관리 API



팀 발표자료에 수록된 관리자 API 문서 화면

개인 산출물 : 관리자 화면 및 CMS API 소스코드 | 사용 기술 : React · FastAPI · Python

관리자 인증 구현과 운영 보완 과제

관리자 인증 구현과 코드 회고 | 운영환경 적용을 위해 추가로 점검할 사항

구현한 인증 흐름

bcrypt 비밀번호 해싱 · 검증

JWT Access / Refresh Token 발급 · 검증

Access 15 분 · Refresh 7 일 만료 설정

HttpOnly · SameSite=Strict 쿠키

로그인 이력 기록, 로그아웃 시 쿠키 삭제

운영 전 보완할 항목

HTTPS 적용 및 Secure=True 설정

토큰 값을 출력하는 디버그 로그 제거

관리자 API 전체의 인증 · 인가 적용 점검

관리자 계정 생성 권한 및 접근 제한 검토

로그아웃 이후 토큰 재사용 방지 검토

개발을 통해 배운 점 : 인증 기능이 존재하는 것과 모든 관리 기능이 보호되는 것은 별개의 확인 과제

커뮤니티 개발에서 배운 점 : 구현과 보호

SeSAC Community | 관리자 페이지 프론트 · 백엔드 구현 경험

화면과 API 의 연결

관리자 화면의 버튼 하나도 요청 형식 , 인증 상태 , 응답 처리와 맞아야 동작했습니다 .
프론트와 백엔드를 함께 맡으며 기능을 화면 단위가 아니라 요청부터 데이터 처리까지 보게 되었습니다 .

인증 이후의 권한

로그인 성공과 토큰 발급은 인증 흐름의 일부입니다 . 코드를 다시 검토하며 각 관리 API 에도
권한 검증이 일관되게 연결되는지 확인해야 하며 , 쿠키 옵션과 토큰 로그도 점검 대상임을 정리했습니다 .

협업과 통합 확인

역할 분담과 소통이 부족하면 작업이 겹치거나 연결 단계에서 차질이 생긴다는 점을 경험했습니다 .
다음에는 API 요청 · 응답 규격과 담당 범위를 먼저 합의하고 , 핵심 기능부터 함께 확인하겠습니다 .

다음 적용 : API 규격 · 역할 합의 → 핵심 기능 연동 → 미인증 · 권한 오류 · 토큰 만료 상황 확인

ISMS-P 갱신 및 수탁사 보안진단

2025.01.06 – 2025.02.25 | 8 인 팀 · 수탁사 조사 4 인 | 교육과정 프로젝트 대상

프로젝트 목적

가상 위탁사 Alpaca Corp. 의 인증 갱신 점검과
수탁사 Bird Delivery 의 보안진단을 함께 수행

담당 업무

수탁사 보안 조사팀에 참여
준거법을 조사하며 체크리스트 1.1~2.1 직접 작성

66 개 점검 항목

53 개 양호

13 개 미흡

수탁사 전체 팀 진단 결과 · 미흡 비율 19.7% · 개선방안을 완료보고서에 정리

개인 수행 : 준거법 조사 · 체크리스트 작성 · 수탁사 조사 참여 | 진단 집계 : 팀 전체 결과

담당 점검 항목과 확인 증거

관련 법령을 직접 살펴보고, 수탁사 체크리스트의 1.1~2.1 항목을 작성했습니다.

담당 항목	확인할 내용	증적 예시
1.1 경영진의 참여	절차와 실제 의사결정 기록	정책 · 지침, 승인 내역, 회의록
1.2 최고책임자의 지정	공식 지정 및 역할	조직도, 책임자 임명 자료
1.3 조직 구성	협의체 구성 및 운영	협의체 규정, 회의록 · 명단
1.4 범위 설정	관리체계 적용 범위	범위 정의서, 시스템 목록
1.5 정책 수립	정책 수립 및 경영진 승인	정책 · 지침, 제 · 개정 공지
2.1 정보자산 식별	분류기준과 자산 목록	정보자산 목록, 식별 내역

법령 검토 : 개인정보 보호법 · 정보통신망법 및 관련 시행령 · 고시와 점검 항목의 연결

진단 사례 : 절차가 있어도 운영 기록은 별도 확인

담당 범위의 1.1 경영진 참여 항목을 통해 판단 과정과 개선 방향을 설명합니다 .

01 현황 확인

정책 · 지침에는
경영진 승인 절차가 존재

실제 의사결정과 참여를
확인할 회의록은 누락

02 판단 근거

문서상 절차만으로는
실제 운영을 입증하기 어려움

사전평가 P
최종 진단 결과 미흡

03 개선 방향

개인정보보호 활동의
의사결정 회의록 작성

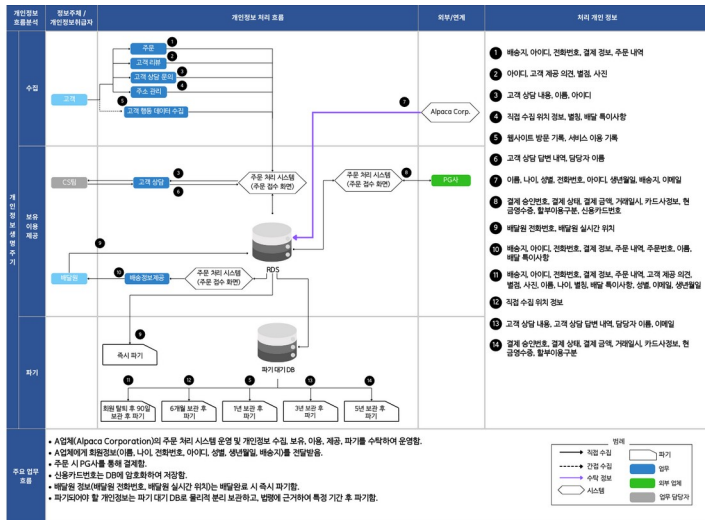
참석 · 승인 · 결정 내용을
확인할 수 있도록 기록

배운 점 : “절차가 있는가” 와 “절차를 실제 이행했는가” 를 구분해 설명

업무 흐름과 시스템 구성을 함께 이해

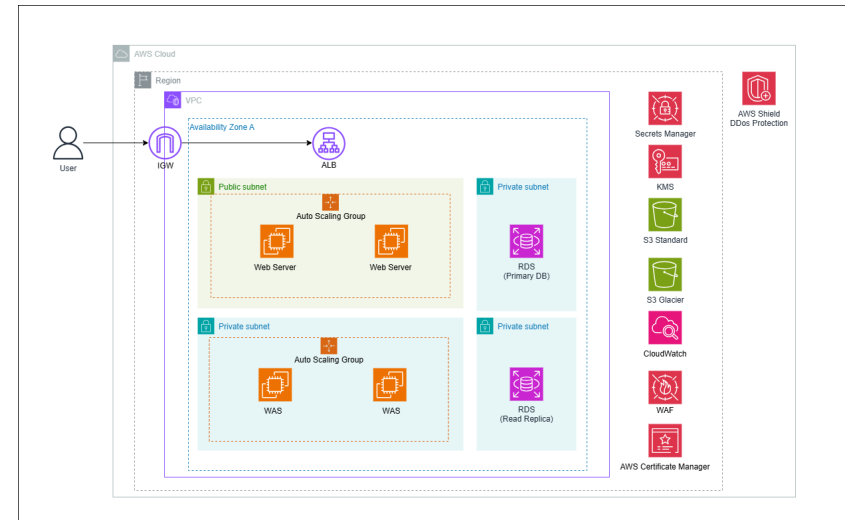
팀 공동 산출물 | 개인정보 흐름도 및 보완 아키텍처

개인정보가 흐르는 경로



전달 정보의 범위, 접근 주체, 보유·파기 흐름을
증적 검토의 맥락으로 이해했습니다.

시스템에 적용하는 보호조치



WAF의 요청 필터링과 KMS의 저장 암호화 키 관리,
민감 로그의 기록 최소화·마스킹을 구분했습니다.

보안진단에서 배운 점 : 판단에 근거를 붙이기

수탁사 보안진단 | 준거법 조사와 체크리스트 1.1~2.1 작성 경험

기준을 확인 질문으로

준거법을 찾아 적는 것에서 끝내지 않고, 어떤 사실을 확인하고 어떤 자료를 받아야 하는지 연결해야 했습니다. 추상적인 요구사항을 실제 점검 질문과 증거 목록으로 바꾸는 과정을 배웠습니다.

미확인과 미이행 구분

경영진 참여 항목에서는 승인 절차가 있어도 운영을 뒷받침할 회의록이 부족했습니다. 기록이 없다는 사실과 활동 자체가 없었다는 판단을 구분하고, 확인된 범위 안에서 설명해야 함을 배웠습니다.

개선으로 이어지는 기록

멘토링을 통해 “미흡”이라는 결론만으로는 상대가 무엇을 바꿔야 할지 알기 어렵다는 점을 배웠습니다. 앞으로는 확인한 현황, 판단 근거, 필요한 조치와 재확인 자료가 이어지도록 결과를 작성하겠습니다.

다음 적용 : 기준 확인 → 증거 검토 → 불명확한 사항 추가 확인 → 조치와 재확인 기준 정리

웹 취약점 진단 : 입력에서 서버 동작까지 따라가기

교육용 실습 환경 | Burp Suite 를 활용한 요청 · 응답 및 인증 · 세션 처리 분석

01 요청 · 응답 관찰

프록시를 통해
HTTP 요청과 응답 확인

파라미터 · 쿠키 · 세션 값이
전달되는 위치 파악

02 입력과 상태 변경

파라미터와 세션 값을
변경하며 응답 비교

SQL Injection · XSS 등
취약점 유형 실습

03 발생 원인 이해

입력값 처리와
인증 · 권한 검증 관찰

서버 처리 흐름과
보안 점검 관점을 연결

점검 관점 : 입력값 처리 · 세션 상태 · 접근권한 · 응답 변화 · 취약점 발생 원인

시스템과 위험을 함께 이해하는 보안 담당자로 성장하겠습니다.

개발 경험으로 서비스의 동작을 이해하고 ,
실습과 점검으로 위험의 원인을 확인하며 ,
근거 있는 설명과 협업으로 개선에 기여하겠습니다 .

윤승찬